Security Incident Report

Cloudora Security Operations | Simulated investigation

Report ID	CLD-IR-0001
Related ticket	CLD-0001 - Suspicious sign-in activity: daniel.reeve@cloudora.io
Report title	Executive account takeover via password spray, with MFA persistence and BEC staging
Analyst	Adithyakrishnan Sureshbabu
Date of report (UTC)	2026-8-10
Incident severity	P1 - executive mailbox compromised during an active enterprise deal; fraud staging in place
Status	Contained - eradication verified, monitoring continues
Classification	Training artifact, public portfolio copy. Cloudora is a fictional client and all data is synthetic

1. Executive summary

Between 8 and 10 August 2026, three IP addresses generated sign-in failures against 26 Cloudora employee accounts in a pattern consistent with password spraying. The supplied source data contains 114 failed events, while the imported query results show 228 failure rows, with repeated records indicating apparent duplication. Successful attacker-associated access affected two accounts: CEO Daniel Reeve's account and employee Priya Nair's account. Following access to the CEO's account, the attacker-associated infrastructure registered an authenticator method named Pixel 6 and created an inbox rule that moves finance and invoice related messages out of the inbox and marks them as read. This creates a credible risk of executive impersonation, payment diversion, missed financial correspondence, and loss of customer confidence while Cloudora approaches an important enterprise deal. The available evidence does not establish that money was stolen, fraudulent messages were sent, or information was exfiltrated. The recommended response is to restrict both affected accounts, revoke sessions, reset credentials, remove unauthorised authentication and mailbox settings, and independently verify sensitive payment instructions. These response actions were not executed within this investigation; recovery remains unverified.

2. Incident timeline

All times UTC. Sources: CloudoraSignIn_CL (sign-in logs), CloudoraAudit_CL (audit logs).

Time (UTC)	Source	Event
Aug 08, 00:00-05:00	Sign-in	Password spray night 1: 88 failed-sign-in rows from the three identified attacker IPs, including apparent duplicate records
Aug 09, 00:00-05:00	Sign-in	Password spray night 2: 72 imported failure rows, corresponding to 36 source events, from the same infrastructure.
Aug 10, 00:35:48	Sign-in	Spray night 3 begins; failed attempt against daniel.reeve from 102.89.44.17
Aug 10, 03:09:12	Sign-in	Failed sign-in, daniel.reeve, 102.89.44.17 (Lagos), ResultType 50126
Aug 10, 03:10:41	Sign-in	Failed sign-in, daniel.reeve, 102.89.44.17, ResultType 50126
Aug 10, 03:12:05	Sign-in	Successful Microsoft 365 sign-in, daniel.reeve, 102.89.44.17, Windows 10 / Chrome 125 - initial access (T1078)
Aug 10, 03:14:30	Sign-in	Successful Outlook Web sign-in against daniel.reeve from 102.89.44.17
Aug 10, 03:18:44	Audit	Attacker registers own authenticator app on daniel.reeve, device 'Pixel 6' - MFA persistence (T1098.005)
Aug 10, 03:26:02	Sign-in	Successful Azure Portal sign-in against daniel.reeve from 102.89.44.17
Aug 10, 03:31:09	Audit	Inbox rule 'RSS Subscriptions' created on daniel.reeve: mail from finance@cloudora.io or containing 'invoice' moved to RSS Feeds and marked read - BEC staging (T1564.008)
Aug 10, 03:44:55	Sign-in	Failed sign-in, priya.nair, 102.89.45.101
Aug 10, 03:47:18	Sign-in	Successful Microsoft sign-in, priya.nair, 102.89.45.101 - second account compromised

Time (UTC)	Source	Event
Aug 10, 03:52:40	Sign-in	Successful SharePoint Online sign-in against priya.nair from 102.89.45.101
Aug 10, 08:41:00	Sign-in	Daniel Reeve's genuine sign-in from London (203.0.113.11, macOS/Safari) - account in use from two countries 5.5 hours apart
Aug 10, 08:55	Ticket	IT admin flags impossible travel on the CEO account; ticket CLD-0001 raised, investigation starts
Aug 10, ~10:30	Response	Containment is recommended for both accounts. Execution time and successful recovery are not evidenced in the supplied logs

3. Findings

Finding 1 - The CEO account was accessed by an attacker, not by Daniel travelling daniel.reeve@cloudora.io authenticated successfully at 03:12:05 UTC on 10 Aug from 102.89.44.17 (Lagos, Nigeria) on a Windows 10 / Chrome 125 device never seen on this account before. The success was immediately preceded by
failed attempts at 03:09 and 03:10 and followed by mailbox access (Outlook Web, 03:14) and Azure Portal access
(03:26). The account's 8-day baseline is exclusively United Kingdom (78 London sign-ins); Daniel signed in normally from London at 08:41 the same morning on his usual macOS/Safari device. Travel and VPN are excluded by the failure pattern, the 3AM timing, the unfamiliar device fingerprint, and the same-day London activity.

Finding 2 - Initial access came from a three-night password spray, not phishing

The three Lagos IPs generated 228 failed sign-ins (ResultType 50126) across 26 distinct accounts between 8 and 10 Aug, concentrated between 00:00 and 05:00 UTC, with only 1-3 attempts per account per night: 102.89.44.17 (96 failures, 23 accounts), 102.89.45.101 (76 failures, 20 accounts), 102.89.44.23 (56 failures, 18 accounts). This
low-and-slow, many-accounts pattern is password spraying (T1110.003), designed to stay under account lockout thresholds.

Finding 3 - The attacker established MFA persistence on the CEO account

At 03:18:44, six minutes after initial access, the audit log records 'User registered security info' on daniel.reeve from 102.89.44.17: an authenticator app on device 'Pixel 6' (T1098.005). With their own MFA method registered, the attacker would survive a password reset - which is why credential reset alone was not treated as containment.

Finding 4 - A BEC inbox rule was staged for invoice fraud

At 03:31:09 the attacker created inbox rule 'RSS Subscriptions' on the CEO mailbox: any mail from finance@cloudora.io or containing 'invoice' is moved to the RSS Feeds folder and marked read (T1564.008). This hides finance conversations from the mailbox owner so the attacker can run invoice fraud from the CEO's identity undetected. No outbound fraudulent mail was observed in the available logs; the rule was staged but, on current evidence, not yet used.

Finding 5 - A second account, priya.nair, was compromised the same night

priya.nair@cloudora.io was successfully accessed from 102.89.45.101 at 03:47:18 after a failed attempt at 03:44:55, followed by SharePoint Online access at 03:52:40. Her baseline is 66 London sign-ins from 203.0.113.10 with no prior foreign activity. No persistence actions appear in the audit log for this account, but the same containment steps were applied (see section 7).

Finding 6 - omar.farah's Dubai activity is legitimate travel (false positive, cleared) omar.farah@cloudora.io shows 24 sign-ins from Dubai (185.93.245.66) across 8-10 Aug. All are daytime (09:00-19:00), all succeed first try with zero failures, and all come from his usual iOS 17 / Mobile Safari device seen throughout his
London baseline. This is consistent travel, not compromise. Note: Omar was also among the 26 spray-targeted accounts
(6 failed Lagos attempts against him, none successful), so he is cleared as a victim but still gets a precautionary reset.

4. Indicators of compromise (IOCs)

Type	Value	First seen (UTC)	Context
IPv4	102.89.44.17	Aug 08, ~00:00	Password-spray source; 96 imported failure rows against 23 accounts. Associated with CEO account access, authenticator registration, and inbox-rule creation
IPv4	102.89.44.23	Aug 08, ~00:00	Password-spray source; 56 imported failure rows against 18 accounts
IPv4	102.89.45.101	Aug 08, ~00:00	Password-spray source; 76 imported failure rows against 20 accounts. Associated with Priya Nair's successful sign-ins
Device fingerprint	Windows 10 / Chrome 125	Aug 08	Shared by attacker-associated records in the supplied source logs. Useful for contextual hunting, but not a unique device identifier
MFA device name	'Pixel 6' (authenticator app)	Aug 10, 03:18:44	Attacker-registered MFA on daniel.reeve - removed
Inbox rule	'RSS Subscription'	Aug 10, 03:31:09	Rule on Daniel's mailbox that moves messages from finance@cloudora.io or containing invoice to RSS Feeds and marks them as read

5. MITRE ATT&CK; mapping

Tactic	Technique ID	Technique name	Evidenced by
Credential Access	T1110.003	Brute Force: Password Spraying	Finding 2 - 228 imported failure rows across 26 distinct accounts, three nights, and three identified IP addresses. Counts include apparent duplicates
Initial Access	T1078	Valid Accounts	Findings 1 and 5 — Successful attacker-associated sign-ins against Daniel Reeve's and Priya Nair's accounts
Persistence	T1098.005	Account Manipulation: Device Registration	Finding 3 — Unauthorised authenticator registration with device name Pixel 6 on Daniel's account at 03:18:44 UTC
Defense Evasion	T1564.008	Hide Artifacts: Email Hiding Rules	Finding 4 — RSS Subscriptions rule created at 03:31:09 UTC to move finance/invoice messages to RSS Feeds and mark them read

6. Scope

Accounts confirmed compromised (2)

- daniel.reeve@cloudora.io — First recorded attacker-associated successful sign-in at 03:12:05 UTC on 10 August 2026, from 102.89.44.17. Subsequent activity included Outlook Web and Azure Portal sign-ins, authenticator registration, and inbox-rule creation.
- priya.nair@cloudora.io — First recorded attacker-associated successful sign-in at 03:47:18 UTC on 10 August 2026, from 102.89.45.101, followed by SharePoint Online access.

Accounts targeted but not breached (24)
The campaign targeted 26 distinct accounts. Excluding the two compromised accounts, the following 24 recorded failed attempts only from the identified attacker infrastructure:
alba.vega, amelia.frost, aria.reid, cole.burke, dina.said, emma.hayes, ethan.wells, freya.lynn, gwen.muir, isla.grant, joel.kerr, jude.ross, kian.patel, leah.stone, lena.voss, liam.doyle, mira.shah, nina.cole, omar.farah, rhys.owen, ruth.dean, ryan.boyd, seth.lane, sofia.marino.(all @cloudora.io)

Accounts investigated and cleared (1)
omar.farah@cloudora.io — Dubai activity was assessed as consistent with legitimate travel based on the successful sign-in pattern and device/browser context. Confirmation with the user would strengthen this assessment.

7. Actions taken

Executed morning of 10 Aug (UTC), in order. In this training scenario these are the documented response decisions; in a live tenant each row would carry the operator and change ticket.

Order	Action	Why this order matters
1	Revoked all active sessions and refresh tokens for daniel.reeve and priya.nair	Kills live attacker sessions immediately; a reset without revocation leaves existing sessions working
2	Reset credentials for both compromised accounts	New credentials only matter once old sessions are dead
3	Removed attacker MFA method 'Pixel 6' from daniel.reeve; reviewed priya.nair MFA methods (no attacker method found)	With attacker MFA in place the account is NOT clean after a reset - this is the back door
4	Deleted inbox rule 'RSS Subscriptions' from daniel.reeve mailbox; audited both mailboxes for further rules	Removes the BEC staging; rules persist independently of credentials
5	Blocked 102.89.44.17, 102.89.44.23, 102.89.45.101 via Conditional Access / named locations	Cuts the known attacker infrastructure off from the tenant
6	Verified: re-ran Step 1 and Step 5 queries - no 102.89.x.x activity after containment; forced re-authentication on both accounts	Containment is a claim until you prove it in the logs

8. Recommendations

- Force password resets for the 24 targeted-but-not-breached accounts listed in section 6 - the spray may have come closer than the logs show.
- Require MFA on all accounts and disable legacy authentication protocols that bypass it; two accounts fell to password-only guessing.
- Alert on new MFA method registration and new inbox rules for executive accounts - both attacker persistence actions were loggable but unmonitored.
- Deploy a password-spray detection rule (failures per IP across distinct accounts in a rolling window) - this attack was visible from night one, two days before the breach.
- Review Conditional Access: block or step-up authentication from countries with no business presence.
- Brief the finance team on BEC risk before the enterprise deal closes: verify any payment-detail change by phone on a known number.

9. Lessons learned

The investigation demonstrated that an executive account compromise must be assessed through its business consequences. Unauthorised authenticator registration and finance-mail concealment created risks involving payment fraud, sensitive correspondence, and customer confidence during an important deal.

Scoping beyond the original alert identified Priya as a second compromised user and established a 26-account target population. Comparing account histories also helped distinguish Omar's likely legitimate travel from the suspicious campaign.

Repeated records materially affected the apparent attack volume. Separating imported rows from source events prevented duplicate data from being reported as additional attacker activity.

Finally, identifying the required response is different from verifying its execution. The incident cannot be described as contained or recovered without evidence that access was restricted, unauthorised settings were removed, and subsequent activity was reviewed.